Note de Pré-Projet — « FasoSouverain » : La Messagerie Souveraine de l'Administration

Hackathon 226 – Édition 2026 (MTDPCE / DGTD) · Sprint Technique Pré-Hackathon

> Cette note décrit l'état **réellement implémenté** du dépôt. Les limites sont assumées dans `NOTE_SECURITE.md`. Les valeurs marquées `[À CONFIRMER]` doivent être vérifiées sur une exécution Docker réelle (voir `docs/PROMPT_VERIFICATION_DOCKER.md`) avant le pitch.

---

1. Concept et Vision Souveraine

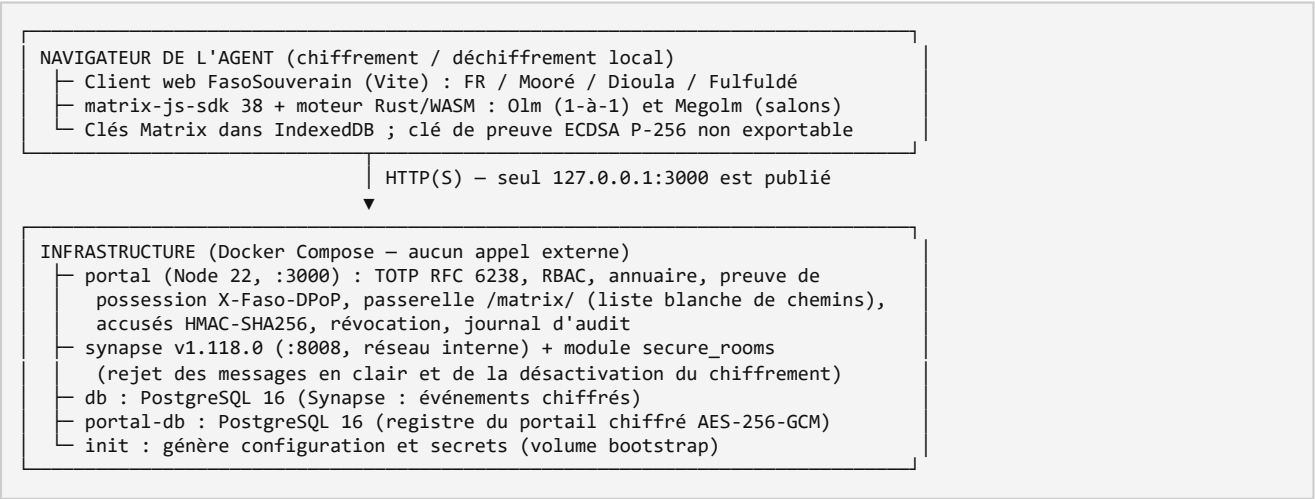
Les agents publics du Burkina Faso échangent quotidiennement des instructions de service, notes ministérielles et rapports opérationnels. L'utilisation de messageries grand public (WhatsApp, Telegram) expose l'État à des risques majeurs de fuite de métadonnées, de dépendance juridique et de coupure de service.

FasoSouverain est une messagerie instantanée souveraine, chiffrée de bout en bout, hébergeable sur les serveurs de l'État (ANPTIC / Data Center national) sans service tiers. Elle s'appuie sur le protocole **Matrix** (serveur **Synapse**, chiffrement **Olm/Megolm** via `matrix-js-sdk`) et ajoute un **Portail Souverain** : authentification forte TOTP obligatoire, rôles, annuaire par administration, cloisonnement entre ministères, classification des messages, instructions de service avec accusé de réception, et interface en **Français, Mooré, Dioula et Fulfuldé**.

Le portail est le **seul point d'entrée** : aucun client Matrix standard (Element) n'est exposé, car il contournerait la 2FA.

---

2. Architecture Technique et Protocole de Chiffrement



Protocole de chiffrement (aucune cryptographie maison)

- **Messages, fichiers et vocaux** : chiffrés dans le navigateur par `matrix-js-sdk` (moteur Rust/WASM).
- **Olm** (Double Ratchet) : échange de clés entre appareils.
- **Megolm** (`m.megolm.v1.aes-sha2`) : chiffrement des salons.
- Pièces jointes chiffrées avant téléversement (`matrix-encrypt-attachment`).
- **Forçage serveur** : `encryption_enabled_by_default_for_room_type: all` et module Synapse `secure_rooms.SecureRooms`. Le serveur ne détient pas les clés de déchiffrement.
- **AES-256-GCM** est utilisé pour le **registre serveur** du portail (agents, secrets TOTP, audit), pas pour les messages.
- **Preuve de possession** `X-Faso-DPoP` : protocole applicatif ECDSA P-256 avec empreintes JWK RFC 7638. Ce n'est **pas** un DPoP conforme à la RFC 9449.

Ce que le serveur voit (honnêteté)

Membres, noms de salons, identités, classifications, échéances, horodatages et tailles des échanges. Il ne voit pas le contenu des messages, fichiers et vocaux.

---

3. Composants Open Source, Licences et Niveau d'Engagement

Composant	Rôle dans l'architecture	Licence	Lien
Matrix Synapse (`v1.118.0`)	Serveur Matrix (routage d'événements chiffrés)	AGPL-3.0	https://github.com/element-hq/synapse
matrix-js-sdk (`^38`) + moteur Rust	Client Matrix, chiffrement Olm/Megolm dans le navigateur	Apache-2.0	https://github.com/matrix-org/matrix-js-sdk
matrix-encrypt-attachment	Chiffrement des pièces jointes	Apache-2.0 `[À CONFIRMER]`	https://www.npmjs.com/package/matrix-encrypt-attachment
PostgreSQL (`16-alpine`)	Deux bases : Synapse et registre du portail	PostgreSQL License	https://www.postgresql.org
Node.js (`22-alpine`)	Exécution du portail	MIT	https://nodejs.org
Vite (`^6`)	Compilation du client web	MIT	https://vitejs.dev
node-postgres (`pg`), **qrcode**, **IBM Plex Sans** (`@fontsource`)	Accès base, QR TOTP, police locale	MIT, MIT, OFL	npm
Portail FasoSouverain (ce dépôt)	TOTP, RBAC, passerelle, innovations métier	**AGPL-3.0-only** (`LICENSE`)	Dépôt de l'équipe

Niveau d'engagement Open Source déclaré : « Étendre et adapter » — extension de Synapse et du SDK Matrix par une couche métier souveraine (`portal/`), sans dépendance payante ou propriétaire, publiée sous AGPLv3.

---

4. Socle de Sécurité et Fonctionnalités pour l'Administration

1. **Identité vérifiée, 2FA TOTP et rôles (RBAC)**
2. Inscriptions publiques fermées (`enable_registration: false`). Seul un `ADMIN_SG` enrôle un agent (matricule, ministère).
3. Mot de passe Matrix de 12 caractères minimum **et** code TOTP à 6 chiffres (RFC 6238), obligatoire avant tout accès Matrix ; tentatives limitées.
4. Le secret TOTP est conservé chiffré côté serveur (ce n'est pas du « zero knowledge »). Le QR n'est transmis qu'avant la validation de l'enrôlement.
5. Rôles : `ADMIN_SG` (enrôlement, révocation, journal), `DIRECTEUR` (instructions de service, messages `Confidentiel État`), `AGENT_PUBLIC` (échanges `Normal` et `Diffusion Restreinte`, accusés).
6. **Cloisonnement par administration** : échanges directs au sein d'un ministère ; demande et acceptation obligatoires entre administrations.
7. **Révocation et bouton d'urgence**
8. La révocation est enregistrée d'abord : sessions du portail coupées immédiatement, puis désactivation Synapse et sortie des salons. Les opérations inachevées sont reprises au démarrage. Utilisable depuis l'interface ou `scripts/revoke.sh`.
9. Le bouton d'urgence efface les clés Matrix locales et demande la désactivation du compte. Un échec réseau est signalé : l'effacement local ne confirme pas la révocation serveur.
10. **Limite** : on ne peut pas retirer les messages ou clés déjà reçus.
11. **Classification** (`Normal`, `Diffusion Restreinte`, `Confidentiel État`) : verrouillage par rôle, sélection de texte limitée et bandeau dans l'interface, **expiration (TTL)** qui masque le message dans l'interface. Le TTL ne garantit pas l'effacement des événements chiffrés ou des sauvegardes. Le blocage de sélection n'empêche pas les captures d'écran.
12. **Instructions de service et accusés** : un directeur marque un message comme instruction ; le destinataire enregistre un accusé horodaté signé **HMAC-SHA256** par le serveur (intégrité). Ce n'est pas une signature personnelle non répudiable.
13. **Langues nationales** : interface en Français, Mooré, Dioula, Fulfuldé. Notes vocales chiffrées de bout en bout (jusqu'à 3 minutes), fichiers jusqu'à 14 Mo.
14. **Annuaire par ministère** : `MTDPCE`, `MEFP`, `MATDS`, `MS`, `SGG-CM`, avec statut d'habilitation.
15. **Récupération des clés** : sauvegarde chiffrée côté client, clé de récupération conservée par l'agent, vérification d'appareil par comparaison de codes (SAS).
16. **Persistance et exploitation** : registre versionné chiffré AES-256-GCM dans `portal-db`, instance unique du portail (verrou PostgreSQL), rétention des IP Synapse à un jour, présence, aperçu d'URL, fédération et télémétrie désactivés.

Vérification du « serveur aveugle »

`scripts/check_server_blind.sh` inspecte les types d'événements stockés dans PostgreSQL. Résultat de la dernière exécution : `[À CONFIRMER]`.

---

5. Tests

- **Tests unitaires** (`npm test` dans `portal/`, fichiers `tests/*.test.js`) : ils utilisent un **moteur Matrix en mémoire** (`matrix_engine.js`) injecté explicitement. Ils valident la logique du portail (TOTP, RBAC, passerelle, révocation), **pas** Synapse ni le chiffrement réel. Résultat : `[À CONFIRMER : N tests, N réussis]`.

- **Tests de bout en bout** (`tests/e2e.cjs`, `tests/synapse-live.cjs`) : navigateur Edge contre la pile Docker réelle (Synapse, chiffrement, récupération, SAS, révocation, redémarrage). Résultat : `[À CONFIRMER]`.
- Au démarrage normal, aucun simulateur n'est utilisé : le portail utilise `SynapseEngine` et échoue visiblement si Synapse est indisponible.

---

6. Répartition des Rôles au sein de l'Équipe

Membre	Rôle principal	Responsabilités techniques (code maîtrisé pour l'entretien)
Membre 1 *(Chef de projet & Sécurité)*	Architecture Matrix & chiffrement	Configuration Synapse (`config/homeserver.yaml.tpl`, `secure_rooms.py`, `init.sh`), client chiffré (`portal/web/matrix.js`, `app.js`), `scripts/check_server_blind.sh`, `NOTE_SECURITE.md`.
Membre 2 *(Backend & Identité)*	2FA, RBAC, passerelle, révocation	TOTP RFC 6238 (`totp.js`), rôles (`roles.js`), passerelle (`gateway.js`), preuve de possession (`dpop.js`), registre (`store.js`), client Synapse (`synapse.js`), `scripts/revoke.sh`, tests (`security.test.js`, `gateway.test.js`).
Membre 3 *(Frontend & Innovations)*	Expérience utilisateur & métier État	Interface multilingue (`i18n.js`), classification et expiration, lecteur vocal (`voice-player.js`), accusés (`receipts.js`), vidéo de démonstration.